01 / 证据先行

LEARN / CLOUD LAB / 待验证

Agent 不是员工人设，而是可撤销授权的岗位

10 个递进疑问 × 内联 SVG × 4 步真实实验

三轮试用是管理启发；五次成功也不是安全证明。

• 实读 AYi 长帖及引用的 distortgeekin 完整文章。文章把岗位五栏、可逆任务、三轮试用、五次干净运行、回滚实测串起来；这些是作者建议，不是平台自动实施的权限。

• OWASP 要求敏感动作的审批绑定主体、工具、目标、规范参数、有效期，并在执行侧原子消费。单纯 user_confirmed=true 不够。

• 本次只运行自编审批逻辑与假令牌，不创建真实岗位、例行任务或外部消息。

查重与增量

总览及《人机协同Interrupt》《沙箱与审批正交》《pass^k可靠性法则》已包含审批与可靠性。本项只追加岗位五栏、试用收据和晋级证据案例，不另造同义概念。

main a8674777e18302b8804b137212b1396cbfe5a747。原帖、官方自述、合成实验和真实产品效果分别标注；不以文件存在冒称全流程完成。

02 / 从概念走到边界

01 为什么先定义岗位，而不先接满工具？

岗位把责任范围固定下来：例如“根据三条公开资料交一份带出处的对比”，而非“管理我的工作”。输入、允许动作、审批点和完成条件必须可检查。接更多工具增加的是事故半径，不自动增加该岗位价值。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

02 五栏职责书具体填什么？

Owns 写终局产物；Inputs 写允许读的资料；May 写可自主执行的可逆动作；Must ask 写发送/发布/付款等边界；Done when 写每条事实都有 URL、日期与未决问题。不能用“高质量”代替验收条件。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

03 为什么第一单要无聊、频繁、可撤回?

频繁提供足够样本，可撤回降低失败成本。先整理合成工单比直接给客户退款更适合暴露去重、误分类和证据缺口。试用不是在生产环境赌博，也不是为“先跑通”放弃安全门。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

04 起草和发送为什么要分开?

草稿文件可审阅、可修改；发送进入别人收件箱，会改变关系与声誉。模型可以完成研究、排序和草拟的安全部分，但到发送点必须停止，展示接收者和正文。一次研究授权不包含发送授权。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

05 审批令牌应该绑定哪些字段？

至少包含当前主体、工具名、目标、规范化参数、有效期、唯一 ID。正文或收件人变动就要新批准。教学脚本只用内容哈希演示变更检测；没有身份认证、签名服务、时效校验，因此不能当生产审批系统。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

06 重放为什么危险？

同一批准被两路执行器消费可能重复发送。执行侧应将“验证并消费”做成原子事务，失败关闭。本次 set 去重仅证明单进程概念，不验证跨进程竞争或外部 exactly-once。重复回执也不能替代业务对账。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

07 三轮试用分别验证什么？

第一轮观察全流程找误解；第二轮换同类任务，确认修的是规则而非临时提醒；第三轮只在审批/歧义点介入。每轮记录完成率、人工介入、审改次数、验收耗时和每个合格结果成本，不能只看是否生成文件。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

08 五次干净交付就能证明可靠？

不能。若单次独立成功概率为 0.8，连续五次成功概率为 0.32768。观察五次成功只能提供有限证据；稀有越权必须靠强制权限控制和对抗样本，而非样本里恰好没发生。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

09 为什么回滚也要真测?

“能撤销”必须指出恢复对象、基线和验证方式。文件可恢复不代表邮件可收回，配置备份不代表数据库事务可逆。本次没有实际系统需要回滚，脚本只验证“未提供回滚证据就不晋级”的规则。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

10 多 Bot 分工的安全边界是什么?

名字和文件夹不是安全隔离。共享电脑上的文件与登录可能被多个 Bot 使用；不同信任级别要靠真实账户/环境隔离。交接只传目标、产物、决定、约束、缺口和下一关，本次不复制私密历史，也不建立长期自动化。



对照本项来源清单、相关查重笔记与实验日志；合成例不是原作者实测。

07 / 能用来做什么、主实验上半段

- 研究岗位职责模板
- 外部发送前审批清单
- 试用期验收记录
- 回滚证据与降级规则

步骤 1 · 填写岗位五栏

目的：填写岗位五栏

```
cd /workspace/chen-jiao-batch2-20261111/item09
python3 exercise/lab.py prepare
```

真实结果（exit=0）：

```
{"owns": "公开资料对比报告", "inputs": ["三条公开资料"], "may": ["read", "draft"], "must_ask": ["send",
"delete"], "done": ["来源齐全", "缺口明确"]}
```

验证：读取 role.json，检查 may 与 must_ask 分开

步骤 2 · 检查动作白名单

目的：检查动作白名单

```
cd /workspace/chen-jiao-batch2-20261111/item09
python3 exercise/lab.py gate
```

真实结果（exit=0）：

```
{'read': 'allow', 'draft': 'allow', 'send': 'park', 'delete': 'park', 'unknown': 'park'}
```

验证：read/draft 放行，send/delete/unknown 暂停

08 / 主实验下半段与诚实边界

步骤 3 · 模拟精确绑定与一次性消费

目的：模拟精确绑定与一次性消费

```
cd /workspace/chen-jiao-batch2-20261111/item09
python3 exercise/lab.py binding
```

真实结果（exit=0）：

```
changed_parameters=rejected replay=rejected; external_sent=0 (local token simulation only)
```

验证：更改正文、重放原批准均被拒；实际发送为零

步骤 4 · 检查晋级必要条件

目的：检查晋级必要条件

```
cd /workspace/chen-jiao-batch2-20261111/item09
python3 exercise/lab.py probation
```

真实结果（exit=0）：

```
5 clean + rollback => eligible; failure/no rollback => denied; 0.8^5= 0.3276800000000001
```

验证：缺回滚证据或最近五次含失败不能晋级

待验证

待验证：真实 Agent 行为、模型随机性、身份认证、数据库原子审批、跨进程竞争和实际回滚。脚本不是平台权限系统。

完整输出不截断保存在 experiment-log.md；输入、脚本与结果位于 exercise.zip。样例和期望由本作者编写，不算独立审核。

09 / 可追溯来源与增量提案

一手材料与固定版本

S1 https://x.com/i/status/2106973630148026785
S1：原长帖 note_tweet 全文

S2 https://x.com/i/status/2105275395901726845
S2：引用文章 plain_text 全文

S3 https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html
S3：官方 AI Agent 安全备忘录，访问日快照

证据目录

sources/ 为公开材料快照；source-manifest.json 记录请求 URL、访问时间与 SHA256。post.json / quoted-posts.json 保存已读文本。哈希用于可追溯，不是对来源结论的认证。访问时间：2026-11-11 01:29:55 北京时间 UTC+8

知识候选

向人机协同Interrupt追加“参数变更重新审批”；向沙箱与审批正交追加岗位职责不是隔离；复用 pass^k 笔记并将“五次”标为管理阈值。